Dossier Pôle Cybersécurité & Conformité RGPD

> Responsable : Léo (pôle Cyber) Projet : Lidl Collect WebApp Drive & Click & Collect Dernière mise à jour : 2026-04-16

1. POURQUOI CE PÔLE EXISTE

Le RGPD impose un ensemble d'obligations documentaires à tout responsable de traitement dès la conception d'un système traitant des données personnelles. Ces obligations ne sont pas optionnelles, même pour un prototype scolaire : elles forment la colonne vertébrale qui justifie chaque choix technique auprès d'un jury, d'un client ou d'une autorité de contrôle (CNIL).

Le pôle Cyber a produit six documents. Chacun répond à une obligation réglementaire précise et génère des contraintes directes sur les autres pôles du projet.

2. ARCHITECTURE DOCUMENTAIRE — VUE D'ENSEMBLE

```
registre-traitement.md          ← source de vérité RGPD (Art. 30)
        │
        ├── alimente ──► politique-effacement.md   (Art. 17 / 20)
        ├── alimente ──► dpia-analyse.md            (Art. 35)
        ├── alimente ──► analyse-sous-traitants.md  (Art. 28 / 46)
        └── alimente ──► matrice-rbac.md            (Art. 5.1.f — limitation accès)
                              │
                              └── alimente ──► threat-model.md  (Art. 32 — sécurité)
```

Le registre est le document racine. Toute modification de la base de données (Sabry) ou de l'architecture applicative (Dorian) doit d'abord être répercutée dans le registre, puis propagée aux autres documents concernés.

3. DESCRIPTION DE CHAQUE DOCUMENT

3.1 — `registre-traitement.md`

Obligation légale : Art. 30 RGPD — tout responsable de traitement de plus de 250 salariés (ou dont le traitement présente des risques) doit tenir un registre écrit des activités de traitement.

Ce que le document contient : 15 activités de traitement (T01 à T15), chacune documentant les données traitées, la finalité, la base légale, la durée de conservation, les acteurs ayant accès et les mesures de sécurité.

Pourquoi chaque champ est obligatoire :

- Base légale : Art. 6 RGPD exige qu'un traitement repose sur l'une des six bases légales. Sans elle, le traitement est illicite.
- Durée de conservation : Art. 5.1.e — principe de limitation de la conservation.
- Mesures de sécurité : Art. 32 — obligation de sécurité appropriée.

Qui peut utiliser ce document :

DESTINATAIRE	USAGE
Dorian (backend)	Chaque traitement liste les tables concernées, les accès autorisés par rôle et les exigences de sécurité à implémenter (guard IDOR, validation DTO, pseudonymisation FK).
Sabry (BDD)	Les durées de conservation déterminent les politiques d'archivage et de purge en base. Le schéma des tables est la source primaire qui alimente le registre.
Willy (auth)	T02 spécifie les durées de token et les exigences de stockage sécurisé (httpOnly cookie).
Jury / client fictif	Preuve de conformité Art. 30 — document produit sur demande de la CNIL.

3.2 — `matrice-rbac.md`

Obligation légale : Art. 5.1.f RGPD (intégrité et confidentialité) + Art. 32 (sécurité par conception). La matrice traduit le principe de moindre privilège en règles d'accès vérifiables.

Ce que le document contient : droits par ressource pour les 4 rôles (CLIENT, OPERATOR, MANAGER, ADMIN), vue RGPD des données accessibles par rôle, configuration JWT de référence, vecteurs d'escalade à protéger, scénarios de test obligatoires.

Pourquoi 4 rôles au lieu de 3 (décision documentée) :

Le cahier des charges initial mentionne trois rôles : CLIENT, OPÉRATEUR, ADMIN. L'ajout du rôle MANAGER est une décision d'architecture de sécurité, prise après analyse des données opérationnelles traitées :

- Un ADMIN a accès à toutes les données de tous les magasins — rôle à exposition maximale.
- Un OPÉRATEUR (préparateur) a besoin d'accéder aux commandes et au stock de son magasin uniquement.
- Un MANAGER a besoin, en sus, d'accéder aux données de performance de son équipe, aux plannings et aux créneaux — données RH sensibles que l'OPÉRATEUR n'a pas à consulter.

Si l'on fusionne MANAGER et OPÉRATEUR dans un seul rôle, ce rôle devrait avoir accès aux données RH de tous ses collègues, ce qui viole le principe de moindre privilège et crée un vecteur de fuite des données de performance inter-pairs. La séparation OPERATOR / MANAGER est donc une contrainte de sécurité, pas du scope creep. Elle aurait dû faire l'objet d'une communication formelle au client — c'est une lacune de processus reconnue.

Qui peut utiliser ce document :

DESTINATAIRE	USAGE
Dorian (backend)	Document de référence pour l'implémentation des guards NestJS. Chaque ligne de la matrice correspond à un guard à coder. Les scénarios de test (section 5) sont les tests d'acceptance obligatoires avant livraison.
Willy (auth)	La section "Configuration JWT" est sa feuille de route : algorithme HS256, durées par rôle, payload minimal, rejet `alg: none`.
Gwen (UX)	La matrice détermine ce que chaque rôle voit dans l'interface — les maquettes doivent correspondre aux droits définis ici.
Jury / client fictif	Preuve de la mise en œuvre du principe de moindre privilège (Art. 5.1.f).

3.3 — `politique-effacement.md`

Obligation légale : Art. 17 RGPD (droit à l'effacement), Art. 20 (portabilité), Art. 12 (délais de réponse de 30 jours), Art. 18 (limitation du traitement), Art. 21 (opposition).

Ce que le document contient : cartographie des données par emplacement, algorithme de pseudonymisation (HMAC-SHA256), procédure de traitement d'une demande d'effacement, spécification des endpoints `DELETE /api/user/me` et `GET /api/user/export`, gestion des sauvegardes Supabase, AuditLog des droits exercés, tableau complet des 7 droits RGPD.

Point de clarification critique — pseudonymisation vs effacement :

La pseudonymisation (HMAC-SHA256 du `client_id`) n'est pas un effacement au sens de l'Art. 17. Les données pseudonymisées restent des données personnelles tant que le sel HMAC existe. La conservation post-demande d'effacement est légale parce que des exceptions à l'Art. 17.3 s'appliquent (obligation légale comptable pour les commandes, constatation de droits en

justice pour les logs). Ces exceptions sont désormais documentées explicitement dans le tableau des tables pseudonymisées. La pseudonymisation vient en complément pour réduire le risque résiduel, pas pour justifier la conservation.

Qui peut utiliser ce document :

DESTINATAIRE	USAGE
Dorian (backend)	Spécification complète des endpoints `DELETE /api/user/me` et `GET /api/user/export` — la transaction PostgreSQL atomique (section 4) est le contrat d'implémentation.
Sabry (BDD)	Les FK à pseudonymiser, les tables à supprimer physiquement et l'algorithme HMAC-SHA256 déterminent le schéma des tables concernées et les procédures de migration.
Jury / client fictif	Preuve du respect des droits des personnes (Art. 17, 20) et de la traçabilité des demandes (AuditLog).

3.4 — `analyse-sous-traitants.md`

Obligation légale : Art. 28 RGPD — tout sous-traitant traitant des données pour le compte du responsable de traitement doit faire l'objet d'un contrat (DPA). Art. 46 — transferts hors UE encadrés.

Ce que le document contient : qualification RGPD de chaque composant (sous-traitant vs composant interne), localisation des serveurs, existence et statut du DPA, certifications, politique de chiffrement, analyse du risque résiduel Nginx.

Sous-traitants identifiés :

COMPOSANT	QUALIFICATION	STATUT
Supabase (Frankfurt)	Sous-traitant Art. 28	✅ Conforme — DPA disponible
Brevo Email	Sous-traitant Art. 28	✅ Conforme — DPA à signer avant production
Brevo SMS	Sous-traitant Art. 28	✅ Conforme — même DPA
Nginx	Composant interne	⚠️ Correction cache requise
Docker	Composant interne	✅ Non concerné

Qui peut utiliser ce document :

DESTINATAIRE	USAGE
Patrice (réseau)	Référence pour la segmentation réseau : les frontières de confiance TB1–TB4 du threat model correspondent aux flux entre composants identifiés ici. Action bloquante : signer le DPA Brevo.
David (DevOps)	La correction Nginx (deux blocs distincts assets/api) est documentée ici et dans le threat model.
Jury / client fictif	Preuve du respect des obligations Art. 28 et de l'absence de transfert hors UE.

3.5 — `dpia-analyse.md`

Obligation légale : Art. 35 RGPD — la DPIA est obligatoire lorsque le traitement est susceptible d'engendrer un risque élevé. La grille CNIL / EDPB (9 critères, seuil à 2) permet d'évaluer cette obligation.

Ce que le document contient : évaluation binaire des 9 critères CNIL, tableau récapitulatif, conclusion (DPIA obligatoire — 2 critères remplis), analyse des risques identifiés, mesures de maîtrise, risques résiduels.

Conclusion révisée : La DPIA est **obligatoire** (critères 1 et 3 pleinement remplis — total 2/9). La présente analyse constitue la DPIA conduite en réponse à cette obligation. Conclusion : les risques résiduels sont acceptables sous réserve que la notice d'information aux préparateurs (Art. L1222-4 Code du travail) soit formalisée avant production.

Qui peut utiliser ce document :

DESTINATAIRE	USAGE
Jury / client fictif	Preuve que l'équipe a correctement évalué l'obligation DPIA et l'a conduite. Un jury DPO-averti notera que la DPIA a été faite, pas esquivée.
Dorian (backend)	Les mesures de maîtrise listées (accès Performance restreint, aucune décision automatisée) se traduisent en guards dans le backend.
Responsable RH (contexte production)	Notice d'information préparateurs à formaliser (obligation légale identifiée).

3.6 — `threat-model.md`

Obligation légale : Art. 32 RGPD — le responsable de traitement doit mettre en œuvre des mesures appropriées pour assurer la sécurité. La modélisation des menaces est la méthodologie standard pour identifier et prioriser ces mesures.

Ce que le document contient : diagramme de flux de données niveau 1, hiérarchie des assets à protéger, analyse STRIDE sur 3 flux (auth, commandes, accès admin) + flux 4 (logique métier, notifications, QR code, IDOR employés), surface d'attaque complète, vecteurs d'escalade, synthèse par criticité, distribution des actions par responsable.

Qui peut utiliser ce document :

DESTINATAIRE	USAGE
Willy (auth)	Section 9 "Distribution des actions → Willy" — liste non négociable des exigences JWT (rejet `alg: none`, `kid` validation, MFA, durées de session).
Dorian (backend)	Section 9 "→ Dorian" — liste des guards et validations à implémenter. Les scénarios de test de la matrice RBAC (section 5 de matrice-rbac.md) sont les tests d'acceptance correspondants.
David (DevOps)	Section 9 "→ David" — deux blocs Nginx distincts (assets / api).
Patrice (réseau)	Section 9 "→ Patrice" — HTTPS obligatoire, rate limiting, segmentation réseau, SPF/DKIM/DMARC.
Jury / client fictif	Preuve d'une démarche structurée de sécurité (Art. 32).

4. DÉPENDANCES REÇUES DES COÉQUIPIERS

Ces informations ont été nécessaires pour compléter les documents cyber. Les lacunes non résolues sont identifiées dans le registre (section "Lacunes documentées").

INFORMATION	FOURNISSEUR	DOCUMENT IMPACTÉ	STATUT
Provider email transactionnel + localisation serveurs	Patrice	registre T06, analyse-sous-traitants #2	✅ Résolu — Brevo (EEE)
Fréquence des sauvegardes Supabase	Sabry	registre T01, analyse-sous-traitants #1, politique-effacement §6	✅ Résolu — WAL continu (doc `BDD/Save_Retention_PITR`)
Confirmation serveurs Supabase Frankfurt	Sabry + David	analyse-sous-traitants #1	✅ Résolu
Durée de rétention logs Nginx	David	registre T13	✅ Résolu — 1 an (Art. L34-1, notes `infradavid/mesnotes.md`)
Confirmation stockage refresh token (httpOnly cookie)	Willy	registre T02, lacune L04	⚠️ Non confirmé — à lever avant production
Schéma complet des tables BDD	Sabry	registre (toutes entrées), politique-effacement	✅ Résolu — `BDD/tables.md`
Confirmation algorithme Bcrypt	Willy	registre T01	✅ Résolu

5. CONTRAINTES IMPOSÉES AUX COÉQUIPIERS

Ces exigences sont non négociables. Elles découlent du RGPD (obligations légales) ou du modèle de menaces (risques critiques). Un livrable qui ne les respecte pas est non conforme.

→ Dorian (backend NestJS)

- `ValidationPipe` global avec `whitelist: true`, `forbidNonWhitelisted: true`, `transform: true` — bloque les mass assignment sur `role` et `storeId`
- `RolesGuard` sur **toutes** les routes sans exception — aucune route sans guard explicite
- `StoreOwnershipGuard` sur toutes les routes OPERATOR et MANAGER (`user.storeId === resource.storeId`)
- Vérification `resource.clientId === req.user.id` sur tout endpoint retournant une ressource par identifiant
- `Cache-Control: private, no-store` via intercepteur global sur toutes les routes protégées par le guard JWT
- Interdiction d'email, téléphone ou mot de passe en clair dans les logs applicatifs NestJS
- Transaction PostgreSQL atomique (BEGIN/COMMIT/ROLLBACK) pour `DELETE /api/user/me`
- `SELECT FOR UPDATE` sur les opérations de stock
- Token de collecte (QR code) généré côté serveur avec CSPRNG, non basé sur l'`orderId`
- Sanitisation de toutes les variables insérées dans les templates de notification Brevo
- Réponse générique unifiée sur `POST /api/auth/login` : pas de distinction "email inconnu" / "mot de passe incorrect"
- Limite de commandes actives par compte (max 3 recommandé)

→ Willy (authentification et tokens)

- Algorithme JWT : HS256 — rejet explicite de `alg: none` dans la configuration NestJS (`algorithms: ['HS256']`)
- Champ `kid` validé contre une liste statique — jamais chargé dynamiquement depuis le payload
- Rate limiting + lockout sur `POST /api/auth/login` (5 tentatives → blocage temporaire)
- Cookies : `httpOnly`, `SameSite=Strict`, `Secure` — rotation stricte des refresh tokens (invalidation du précédent à chaque renouvellement)
- MFA obligatoire pour OPERATOR, MANAGER et ADMIN (pas seulement ADMIN)
- Durées de session : CLIENT 15 min access / 7 j refresh — OPERATOR et MANAGER 15 min / 8 h — ADMIN 10 min / 4 h
- Payload JWT minimal : `userId`, `role`, `storeId` uniquement — aucune donnée personnelle (nom, email, téléphone)

- Confirmation du mécanisme de stockage du refresh token (httpOnly cookie) — lacune L04 encore ouverte

→ David (infrastructure Docker / Nginx)

- Deux blocs Nginx distincts obligatoires : bloc `/` avec cache activé pour les assets statiques, bloc `/api/` avec `proxy_no_cache 1` et `proxy_cache_bypass 1`
- Aucune route API ne doit passer par le cache Nginx — risque de fuite inter-sessions (menace I2.3 du threat model)
- Headers de sécurité HTTP sur toutes les réponses Nginx : `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy`

→ Patrice (infrastructure réseau)

- HTTPS obligatoire sur toutes les routes en production — aucune route HTTP en clair
- Rate limiting Nginx sur les routes publiques (authentification, catalogue)
- Segmentation réseau : PostgreSQL non exposé directement sur Internet (zone privée TB3)
- DPA Brevo à signer avant mise en production — action bloquante
- Configuration SPF, DKIM, DMARC sur le domaine expéditeur Brevo
- Rotation régulière des clés API Brevo + surveillance des envois anormaux
- Surveillance du volume d'actions ADMIN (alertes sur anomalies)

→ Sabry (base de données)

- Toute modification du schéma (ajout de table, modification de FK) doit être communiquée à Léo pour mise à jour du registre de traitement
- Les tables `Order`, `OrderItem`, `Payment`, `SubstitutionProposal` doivent conserver leurs FK clients même après effacement — la pseudonymisation les modifie, pas les supprime
- La table `Consent` ne doit jamais être supprimée physiquement — pseudonymisation uniquement
- La table `AuditLog` est en append-only — aucune opération DELETE autorisée en base

6. COHÉRENCE INTER-DOCUMENTS — POINTS DE VÉRIFICATION

Ces points garantissent que les six documents ne se contredisent pas.

POINT DE COHÉRENCE	DOCUMENT A	DOCUMENT B	STATUT
Durées de conservation des tables pseudonymisées	politique-effacement.md §1	registre-traitement.md (entrées T03, T08, T12)	✅ Alignés
Qualification sous-traitant Supabase (Frankfurt)	analyse-sous-traitants.md #1	registre-traitement.md (mention transfert hors UE)	✅ Alignés
Brevo Email et SMS (AWS Irlande EEE)	analyse-sous-traitants.md #2 et #3	registre-traitement.md T06	✅ Alignés
Abandon de Redis	analyse-sous-traitants.md §Nginx	politique-effacement.md (note Redis)	✅ Alignés
Algorithme pseudonymisation HMAC-SHA256	politique-effacement.md §2	threat-model.md (asset HMAC_SECRET)	✅ Alignés
Durées JWT par rôle	matrice-rbac.md §Configuration JWT	registre-traitement.md T02	✅ Alignés
Accès Performance : Manager et Admin uniquement	matrice-rbac.md (droits RBAC)	dpia-analyse.md (mesure de maîtrise)	✅ Alignés
DPIA obligatoire (2 critères remplis)	dpia-analyse.md	registre-traitement.md T12 ("voir dpia-analyse.md")	✅ Alignés
Cache Nginx : correction requise	analyse-sous-traitants.md §Nginx	threat-model.md I2.3	✅ Alignés
Art. 17.3 exceptions par catégorie	politique-effacement.md §1	registre-traitement.md (bases légales de conservation)	✅ Alignés

← **registre-traitement.md** | → **matrice-rbac.md** | → **threat-model.md**